

Zabezpieczenia Infrastruktury LAN: Warstwa Druga

Architektura zaufania, mechanizmy **obronne** i pułapki wdrożeniowe. Kompendium do modułu 4.

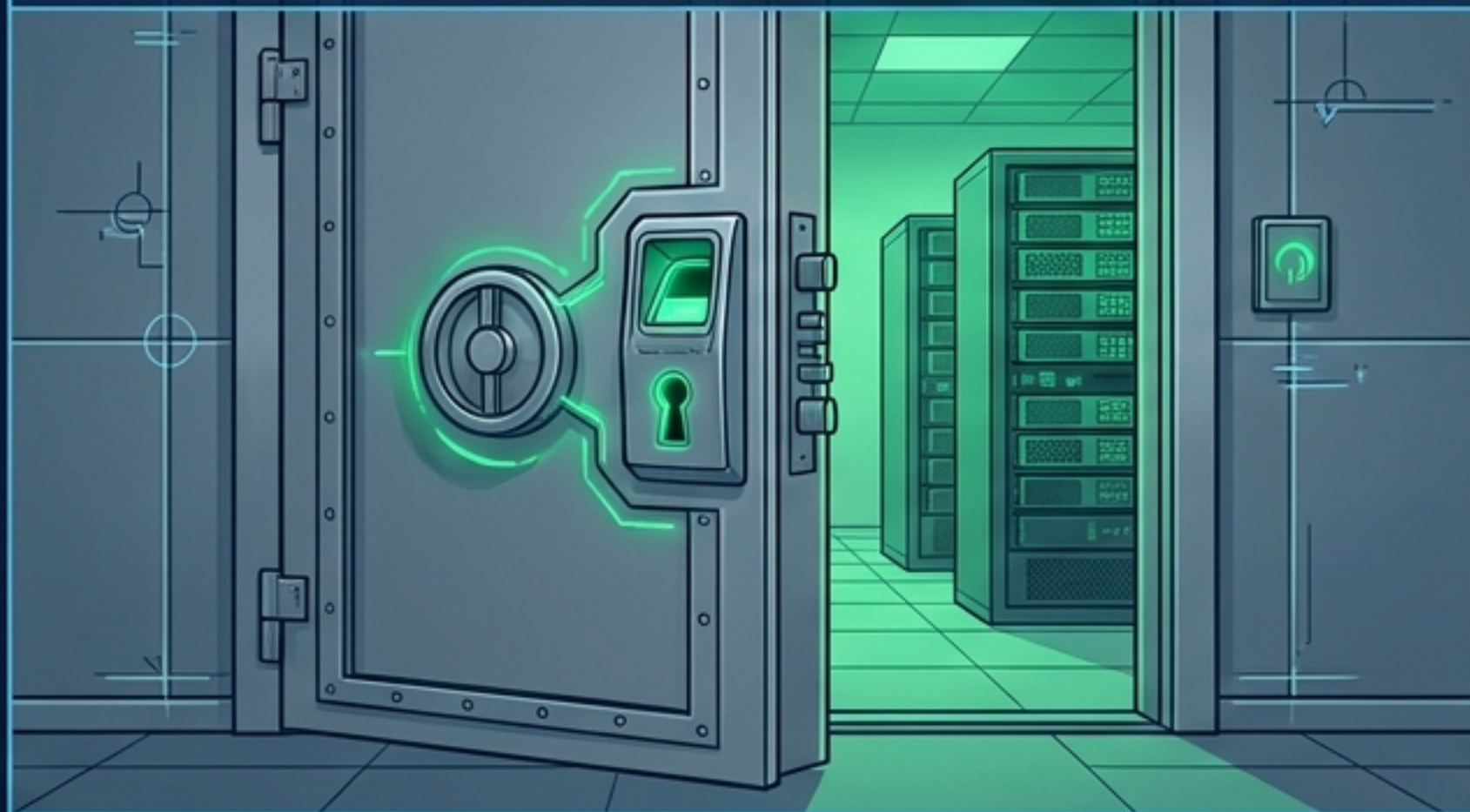


Przygotowano dla uczestników kursu
Projektowanie, wdrażanie i administracja sieci LAN (Mariusz Gola)

Grzech pierworodny warstwy drugiej

Protokoły Ethernet, ARP i DHCP powstały dla **zamkniętych sieci zaufanych**. **Nie weryfikują tożsamości nadawcy.**

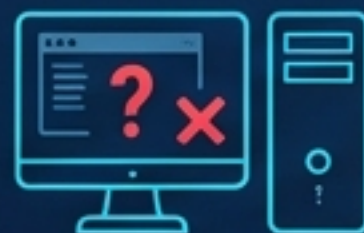
Lata 90: Zaufanie fizyczne



Dziś: Zagrożenie w gnieździe



Przełącznik wierzy
każdej ramce i ślepo
uczy się adresów MAC.

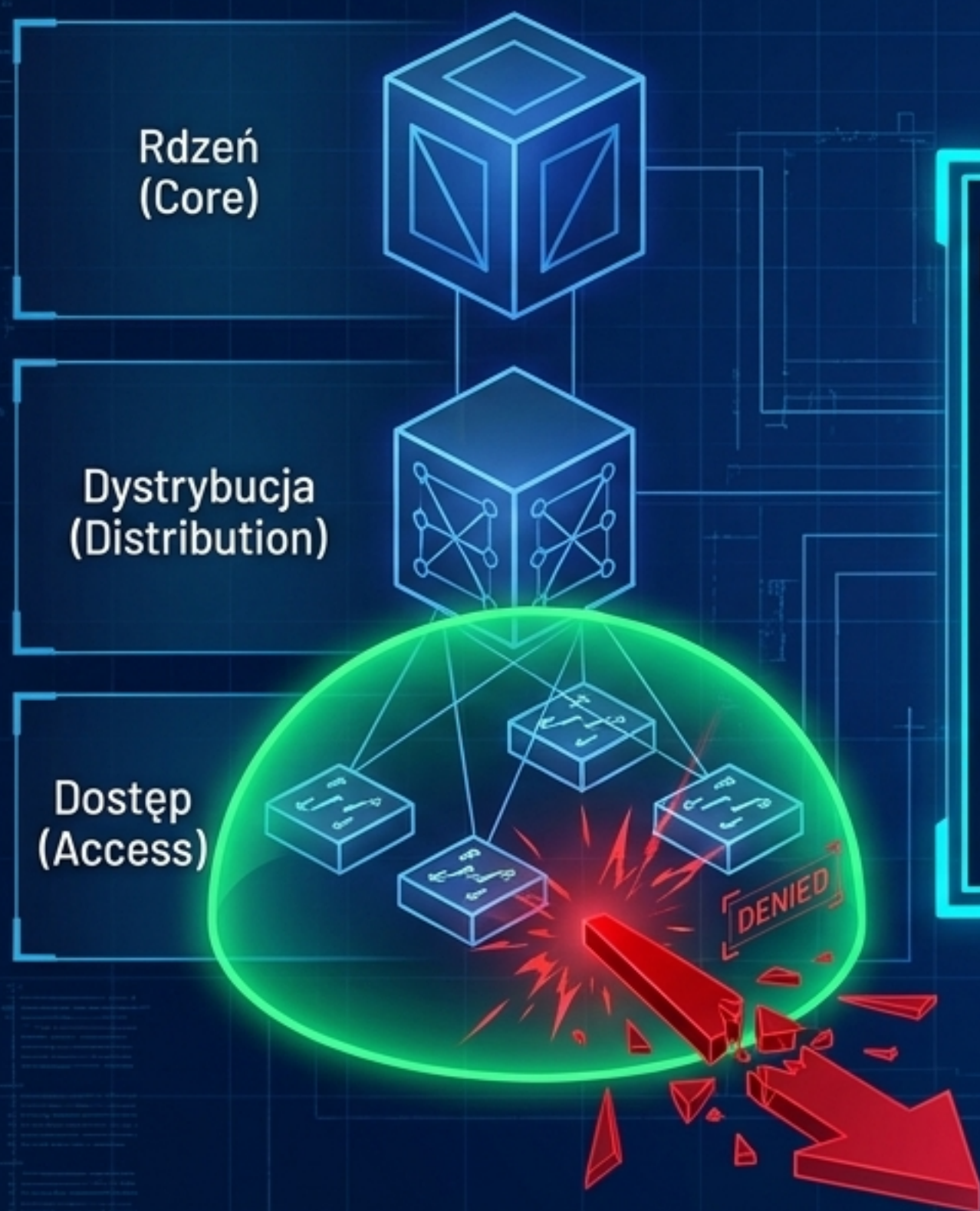


Stacja przyjmuje
odpowiedzi ARP, o
które nigdy nie pytała.



Klient akceptuje
pierwszą ofertę DHCP,
niezależnie kto ją wysłał.

Złota zasada bezpieczeństwa brzegu sieci



Kontrolę stosuje się
na **pierwszym**
urządzeniu, do
którego podłącza
się użytkownik, i
nigdy nie powtarza
na kolejnych.

1.

1. Odrzucenie wrogiego ruchu nie obciąża rdzenia sieci.



2.

2. Tylko przełącznik dostępowy zna topologię fizyczną stacji końcowych.

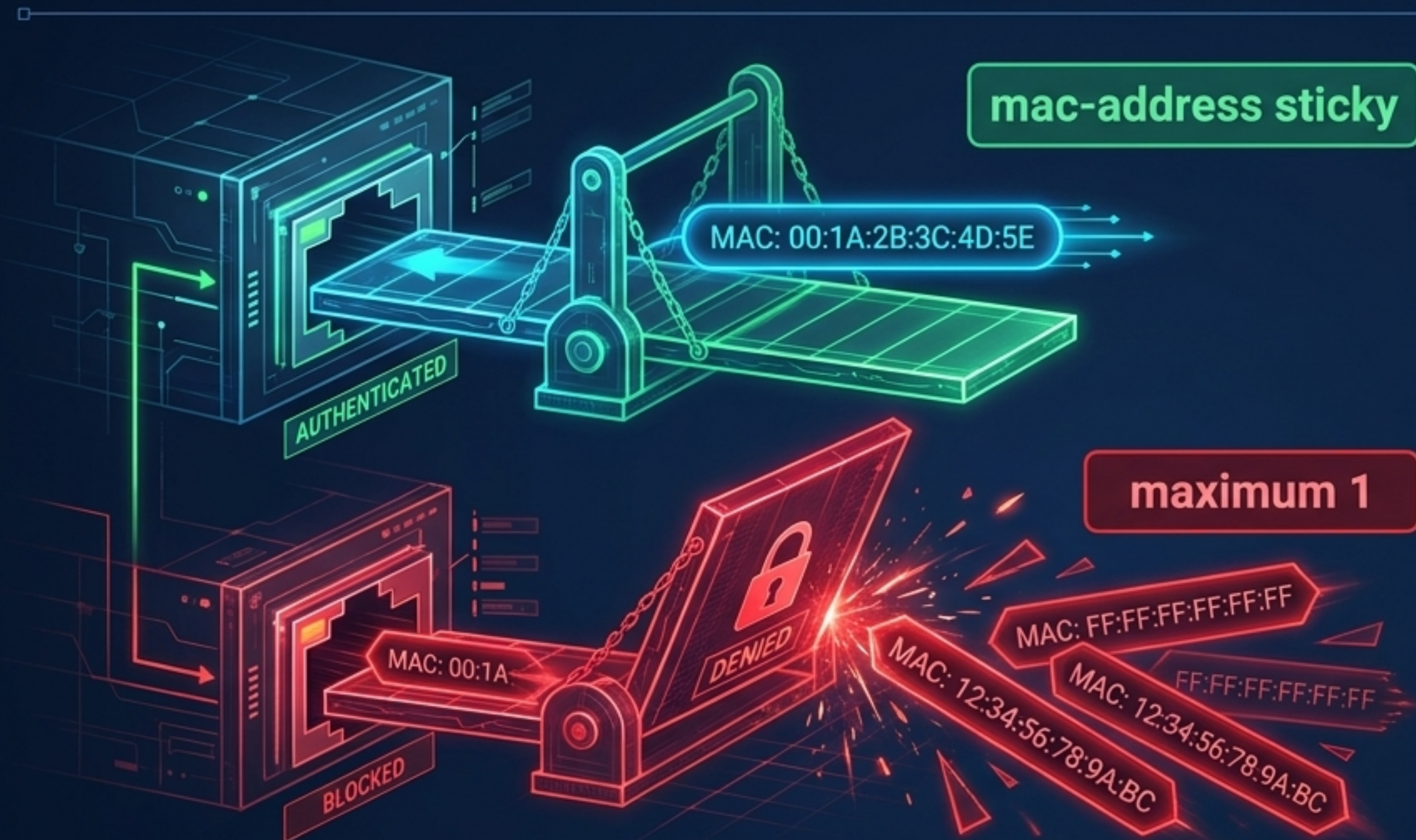


3.

3. Próba weryfikacji L2 na kolejnych warstwach odrzuca prawidłowy ruch (brak wiedzy o lokalnych portach sąsiada).



Port Security: Cyfrowy most zwodzony



Zadanie:

Ogranicza liczbę adresów MAC na porcie (blokuje zalewanie tablicy i wyczerpanie puli DHCP).

Sticky:

Przełącznik uczy się pierwszego adresu z ruchu i zapisuje go w konfiguracji (wymaga **write memory** by przetrwać restart).



Czego Port Security nie chroni? Nie sprawdza tożsamości – sfałszowany (sklonowany) adres MAC uprawnionej stacji przejdzie bez problemu.

Tryby naruszenia: Kompromis między bezpieczeństwem a obsługą

	Protect	Restrict	Shutdown
Akcja dla ramki	🚫 Odrzucana	🛡️ Odrzucana	🛡️ Odrzucana
Stan Portu	✅ Działa	✅ Działa	🚫 err-disabled
Licznik naruszeń	↗ Nie rośnie	↑ Rośnie	↑ Rośnie
Alerty	🔔 Brak śladu	🔔 SNMP / Syslog	🔔 Konsola / Syslog
Zastosowanie	Rzadko stosowany (najsłabszy)	Gniazda publiczne, sale konferencyjne (duża rotacja)	Domyślny; stanowiska biurowe (najwyższe bezpieczeństwo)

Pułapka stanu err-disabled

Port jest włączony administracyjnie, ale wyłączony programowo.



Simulator Badge

Ograniczenie:
Automatyczne odtwarzanie (recovery) nie jest obsługiwane w Packet Tracer. Odtwarzaj ręcznie.

Podatność DHCP: Wyścig z czasem



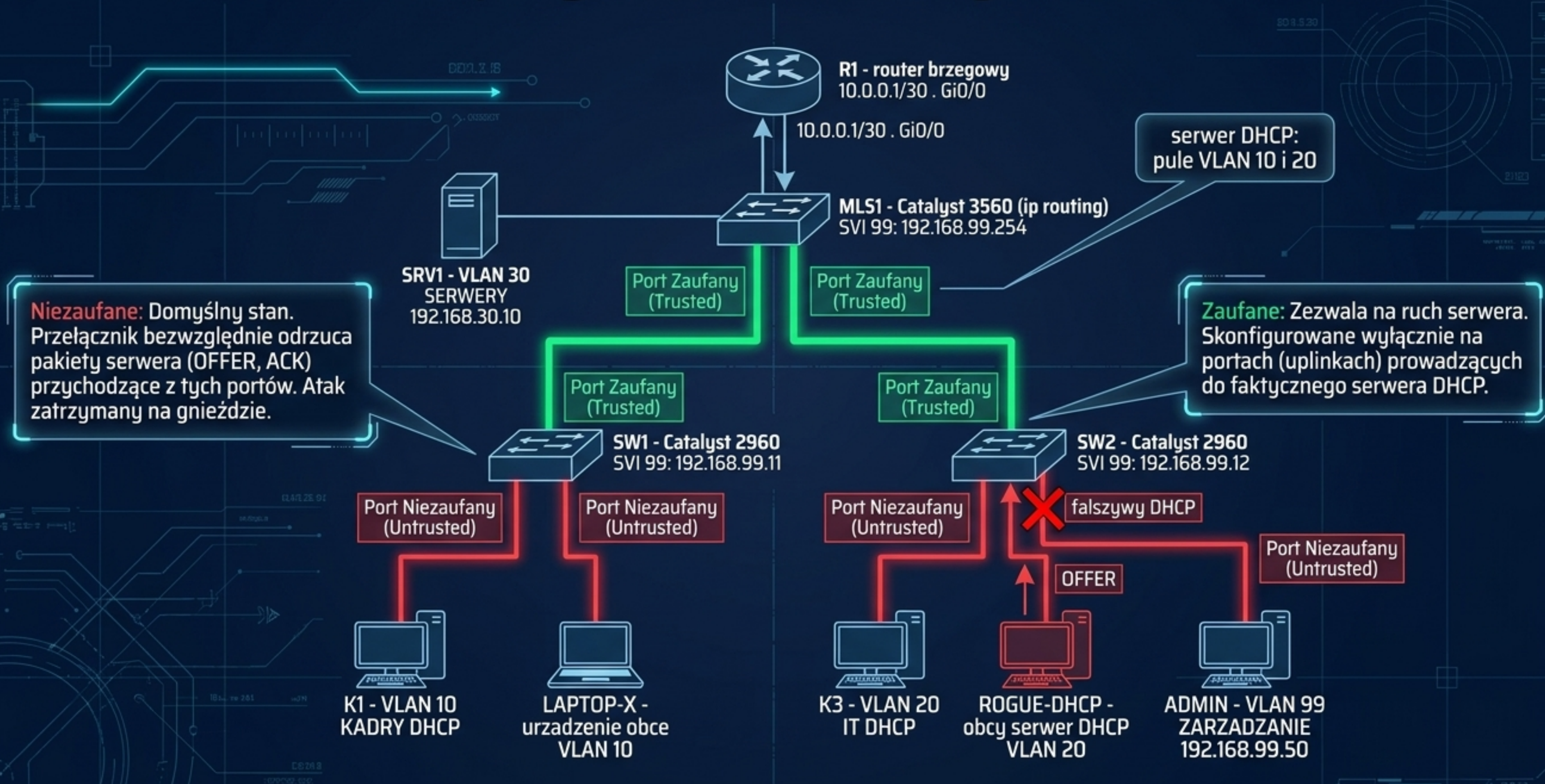
Błąd logiczny:

Klient akceptuje pierwszą ofertę, która do niego dotrze. Obcy serwer w tej samej sieci VLAN zawsze wygrywa z serwerem w oddalonej serwerowni.

Najgroźniejszy skutek:

Atak przydziela fałszywy serwer DNS. Użytkownik wpisuje poprawny adres URL i trafia na serwer napastnika (brak widocznych objawów awarii dla ofiary).

DHCP Snooping: Architektura granic zaufania



Baza Prawdy: Tablica powiązań (Binding Database)



MAC	IP	VLAN	Port	Lease
00:50:56:8A:1B:2C	192.168.10.15	10	Gi1/0/2	7 days
A4:BB:6D:EF:01:A1	192.168.20.30	20	Gi1/0/5	8 hours

Mechanizm: DHCP Snooping podsłuchuje komunikację (DHCPACK) na portach niezauważanych i buduje ewidencję. Urządzenie ze statycznym IP nie wysyła zapytań = brak wpisu.

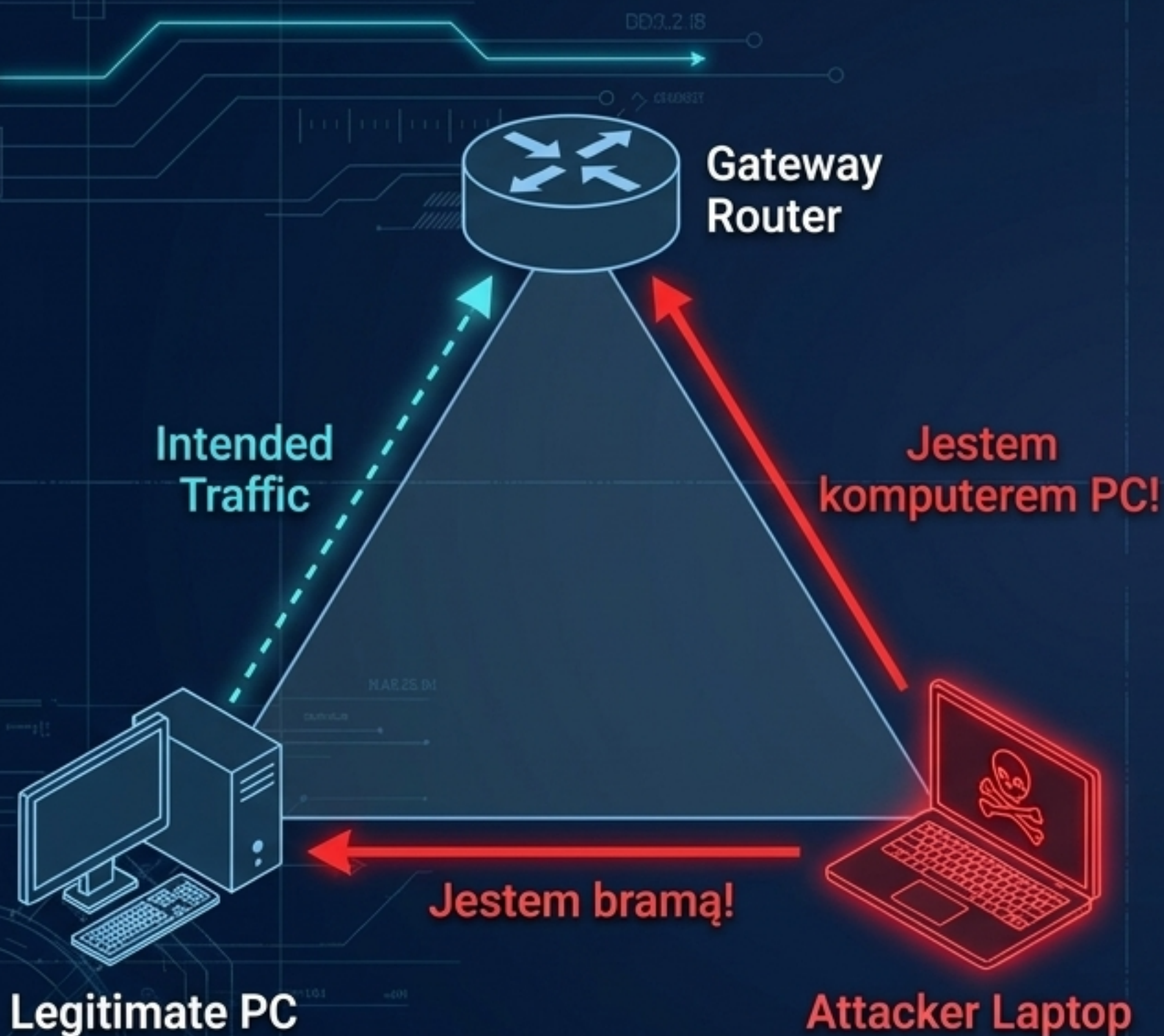
⚠ Krytyczna pułapka wdrożeniowa: Opcja 82 ⚠

Problem: Domyślnie przełącznik dokleja Opcję 82, zerując giaddr. Przełączniki warstwy 3 (np. MLS1) odrzucą taki pakiet.

Objaw: Po włączeniu DHCP Snooping nagle nikt w sieci nie dostaje IP!

Rozwiązanie: Zawsze dodawaj polecenie no ip dhcp snooping information option (lub ustaw trust-all na routerze).

ARP Spoofing: Cichy człowiek pośrodku



- **Podatność protokołu:** ARP działa bez uwierzytelniania. Każde urządzenie w sieci może ogłosić: Ten adres IP należy do mojego adresu MAC.
- **Niewidzialny efekt:** Płaska sieć L2 pozwala na przekierowanie całego ruchu segmentu przez maszynę napastnika (Bettercap, Ettercap). Ping i Traceroute nie pokażą błędu, ponieważ adresy IP w nagłówkach L3 pozostają całkowicie niezmienione.

Dynamic ARP Inspection (DAI): Anatomia weryfikacji

Dissection

Nagłówek Ethernet

MAC Nadawcy: 00:50:56:8A:1B:2C

Komunikat ARP

MAC Nadawcy: A4:BB:6D:EF:01:A1



Rozbieżność:
Taktyka Atakującego!

Verification

Baza Powiązań DHCP Snooping



MAC: 00:50:56:8A:1B:2C,
IP: 192.168.10.15

MAC: 60:50:56:8A:1B:2C,
IP: 102.168.10.15

✓
Poprawne
Query

✗
Odrzucone

Logika działania: DAI przechwytuje każdą ramkę ARP i sprawdza, czy para IP-MAC istnieje w Bazie Powiązań. Brak wpisu lub niezgodność = natychmiastowe odrzucenie ramki.

Deep Validation Command

`validate src-mac dst-mac ip`

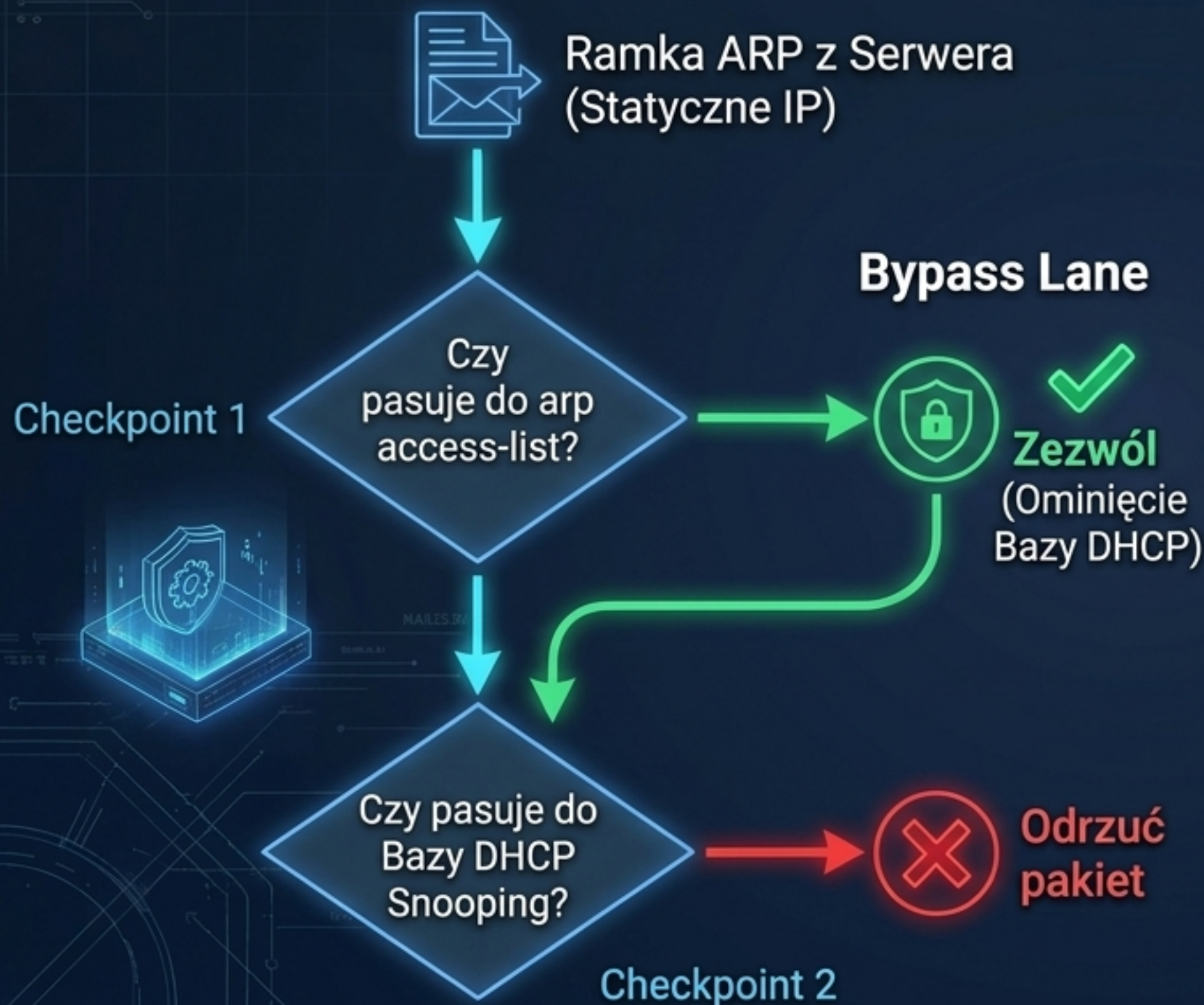
- Sprawdza rozbieżności między nagłówkiem L2 a ciałem komunikatu ARP.
- Pułapka konfiguracyjna: Kolejne wywołanie komendy nadpisuje poprzednie! Wszystkie parametry muszą być umieszczone w jednej linii.



Simulator Badge

Ograniczenie: Walidacja rozszerzona (validate) niedostępna w programie Packet Tracer.

Wyjątek od reguły: Urządzenia ze statycznym IP



- **Problem:** Serwery i drukarki nie używają DHCP. DAI odetnie im komunikację, ponieważ nie ma ich w Bazie Powiązań.
- **Rozwiązanie:** Tworzenie arp access-list wiążącej adres IP bezpośrednio z adresem MAC urządzenia.
- **Krytyczny Krok:** Sama lista nie zadziała! Musi zostać przypisana do sieci VLAN poleceniem:

```
ip arp inspection filter [NAZWA] vlan [ID]
```


Dodanie słowa 'static' na końcu polecenia wymusza poleganie wyłącznie na liście ACL.

Architektura bezpieczeństwa: Łańcuch zależności



✓ Zabezpieczenia L2 nie są izolowane. Muszą być wdrażane w ścisłej kolejności.

- ✓ 1. **Fundament (Port Security):** Chroni przed zalaniem tablicy MAC i wyczerpaniem puli DHCP z pojedynczego gniazda.
- ✓ 2. **Konstruktor Bazy (DHCP Snooping):** Zatrzymuje fałszywe serwery DHCP i buduje rzetelną ewidencję przydziałów adresów na portach.
- ✓ 3. **Konsument Bazy (DAI):** Zapobiega atakom MITM (ARP Spoofing), ale jest całkowicie ślepy i bezużyteczny bez bazy zbudowanej przez mechanizm Snooping.

Fatalny błąd wdrożeniowy: Włączenie DAI przed uruchomieniem DHCP Snooping (i odnowieniem dzierżaw) natychmiast odcina od sieci wszystkich klientów!

Top 5 pułapek wdrożeniowych na produkcji

Błąd konfiguracji (Trap)	Objaw na produkcji (Symptom)
 Opcja 82 włączona domyślnie.	 Wszyscy klienci nagle tracą dzierżawy DHCP po włączeniu snoopingu.
 Uplink w stronę serwera pozostawiony jako niezauwany.	 Brama staje się nieosiągalna; błędna diagnoza 'nie działa internet'.
 Brak komendy zapisu bazy (dhcp snooping database).	 Po planowym restarcie przełącznika klienci nie mają sieci (aż do odnowienia dzierżawy).
 DAI włączone przed inwentaryzacją statycznych IP.	 Natychmiastowe odrzucenie prawidłowego ruchu z serwerów, punktów AP i drukarek.
 Powtarzanie komendy 'validate' w nowych liniach.	 Ostatni wpis nadpisuje wszystkie poprzednie; weryfikacja ramki jest niepełna.